Saudi GRC Platform

Workflow Catalogue

Source: `workflow-catalogue.md`

03 — Workflow Catalogue

Every workflow in the platform, English + Arabic name, state machine, SLA, escalation, evidence, signature requirement. Anchored to the actual service classes that own the state transitions.

Common conventions:

- **Audit trail**: every transition writes to `BaseEntity.updatedAt` + realtime broadcaster `changed.{entity}`. Sensitive transitions (approve, reject, sign) also log to `audit.events`.
- **Notifications**: routed through `notification.outbox` + channels.
- **Digital signature**: optional per workflow; some are mandatory (see table column).
- **Lifecycle**: every workflow ends in a terminal status; no re-open without explicit revoke transition.

BCM Workflows

BCM Governance

- **AR**: ■■■■■■ ■■■■■■■■■■ ■■■■■■■■
- **Purpose**: charter the BCM programme, define committee, set policy.
- **Trigger**: programme start or annual review.
- **Pre-conditions**: executive sponsor named.
- **Steps**: draft charter → executive review → board approve → publish → annual review.
- **Roles**: BCM Manager (draft), Executive Sponsor (review), Board (approve).
- **Approval matrix**: 2 levels — Executive + Board.
- **Inputs**: organisation chart, regulatory drivers, prior charter.
- **Outputs**: signed charter; mapped to `evidence.evidence_items` with type `BCM_CHARTER`.
- **Evidence**: charter PDF + signature transaction.
- **Modules**: BCM, Compliance, Admin (committees).
- **Registers**: `bcm.bcm_plans` (charter row), `admin.committees`.
- **Notifications**: board calendar invite, charter publish notice.
- **SLA**: 90 days from policy expiry to renewal.
- **Escalation**: at -30 days notify Executive Sponsor.
- **Status lifecycle**: DRAFT → IN_REVIEW → APPROVED → ACTIVE → ARCHIVED.
- **Audit**: full history retained in `audit.events`.
- **Signature**: required at APPROVED.

Critical Service Identification

- **AR**: ■■■■■■ ■■■■■■■■ ■■■■■■■
- **Purpose**: list every service the org delivers, classify criticality.
- **Trigger**: annual or change-driven.
- **Pre-conditions**: service inventory imported.

- **Steps**: service owner submits → BCM reviews → BIA owner classifies → Risk Manager endorses.
- **Roles**: Service Owner, BCM Manager, Risk Manager.
- **Status**: DRAFT → CLASSIFIED → APPROVED.
- **SLA**: 14 days from import.
- **Modules**: BCM, ERM. **Registers**: `bcm.critical_processes`.
- **Signature**: not required (record approval is enough).

Business Impact Analysis (BIA)

- **AR**: ■■■■■ ■■■ ■■■■■■■
- **Purpose**: quantify MTPD/RTO/RPO per critical service.
- **Trigger**: new service, annual cycle, post-incident.
- **Steps**: scoping → impact scoring (financial, regulatory, reputational, operational) → dependency capture → RTO/RPO set → review → approve.
- **Roles**: BIA Owner, Service Owner, Risk Manager, BCM Manager.
- **Approval**: BIA Owner submits → BCM Manager approves.
- **Outputs**: BIA record with `mtpd`, `rto`, `rpo`, `mbco`, dependencies.
- **Evidence**: BIA report PDF, dependency map screenshot.
- **Status**: DRAFT → SCORING → IN_REVIEW → APPROVED → SUPERSEDED.
- **SLA**: 21 days from BIA initiation.
- **Escalation**: at -3 days notify BCM Manager; at +0 escalate to Risk Committee.
- **Signature**: required at APPROVED.
- **Registers**: `bcm.bia_records`.

BCM Risk Assessment

- **AR**: ■■■■■ ■■■■■ ■■■■■■■■■■ ■■■■■■■■
- Risk-assessment workflow scoped to continuity events.
- **Trigger**: post-BIA.
- **Roles**: BCM Manager, Risk Manager.
- **Status**: DRAFT → ASSESSED → APPROVED.
- **Modules**: BCM, ERM (linked risk).
- **Signature**: optional.

Business Continuity Strategy

- **AR**: ■■■■■■■■■■■ ■■■■■■■■■■ ■■■■■■■■
- Choose treatment (hot/warm/cold/active-active/cloud-DR) per critical service.
- **Trigger**: post-BIA approval.
- **Roles**: BCM Manager, CIO, CFO.
- **Status**: DRAFT → APPROVED.
- **Signature**: required at APPROVED.

BCP Development

- **AR**: ■■■■■■ ■■■■ ■■■■■■■■■■ ■■■■■■■■
- Build the BCP document with named teams, comms tree, alternate site.
- **Steps**: draft → peer review → BCM approve → publish.
- **Roles**: BCM Manager (owner), Service Owner (reviewer).
- **Status**: DRAFT → IN_REVIEW → APPROVED → ACTIVE → ARCHIVED.
- **Evidence**: BCP PDF, comms tree.
- **Signature**: required at APPROVED.
- **Registers**: `bcm.bcm_plans`.

IT Disaster Recovery (DRP)

- **AR**: ■■■■ ■■■■■■■■ ■■■■■■■ ■■ ■■■■■■■■
- DRP playbook per system with RTO/RPO, failover + failback steps, site type, test schedule.
- **Steps**: draft → peer review → approve → activate → test (record outcome) → fail-back.
- **Roles**: DR Owner, CIO, BCM Manager.
- **Status**: DRAFT → IN_REVIEW → APPROVED → ACTIVATED → ARCHIVED (with REJECTED side-branch).
- **Module**: BCM (`module/bcm/drp/`). **Service**: `DrPlanService`.
- **Test action**: `recordTest(outcome, nextTestDue)`.
- **SLA**: annual test minimum; quarterly for tier-1 systems.
- **Signature**: required at APPROVED + at each test sign-off.

Crisis and Emergency Activation

- **AR**: ■■■■■■ ■■■■■■■■ ■■■■■■■■■
- Declare crisis → invoke plans → standing communications.
- **Trigger**: incident severity threshold, manual declaration.
- **Roles**: Crisis Manager, Executive Sponsor, BCM Manager.
- **Status**: DECLARED → STANDUP → STANDDOWN → POST_MORTEM.
- **SLA**: 30-minute stand-up window.
- **Escalation**: auto-page Crisis Manager.
- **Modules**: BCM, Incident.
- **Evidence**: declaration log, comms record, after-action.
- **Signature**: required at POST_MORTEM close.

Communication Management

- **AR**: ■■■■■■ ■■■■■■■■■■
- Pre-approved templates + audiences + distribution lists, exercised under crisis.
- **Roles**: Comms Lead, Crisis Manager.
- **Registers**: `bcm.crisis_comms_templates`, `bcm.crisis_audiences`, `bcm.crisis_distributions`.

- **Signature**: not typically required.

BCM Testing and Exercises

- **AR**: [redacted]
- Schedule → run → after-action → corrective actions.
- **Roles**: Exercise Facilitator, BCM Manager.
- **Status**: SCHEDULED → IN_PROGRESS → COMPLETED → APPROVED.
- **Outputs**: after-action report, CAPA items.
- **Registers**: `bcm.exercises`.
- **Signature**: optional.

Lessons Learned

- **AR**: [redacted]
- Capture lessons from incidents + exercises + BCM invocations.
- **Roles**: BCM Manager + RCA Facilitator.
- **Status**: DRAFT → APPROVED.
- **Integration**: feeds CAPA + future BIA cycles.
- **Signature**: not required.

Corrective Actions (BCM)

- **AR**: [redacted]
- Tracks BCM-origin CAPAs.
- **Module**: `capa/`. **Origin types**: `bcm_exercise`, `bcm_invocation`, `rca`.
- **Status**: OPEN → IN_PROGRESS → AWAITING_VERIFICATION → CLOSED / CANCELLED.
- **Signature**: at CLOSED for high-severity items.

BCM Compliance Evidence

- **AR**: [redacted]
- Periodic evidence collection mapped to ISO 22301 + SAMA + NCA controls.
- **Module**: Evidence.
- **Signature**: per evidence (see Output 6).

Management Review (BCM)

- **AR**: [redacted]
- Annual top-down review per ISO 22301 clause 9.3.
- **Roles**: Executive Sponsor, BCM Manager, Risk Manager.
- **Output**: management-review minutes + actions.
- **Signature**: required (executive sign-off).

Supply Chain Resilience Workflows

Supplier Registration

- **AR**: ■■■■■■ ■■■■■■■
- New vendor record creation, validation, KYC checks.
- **Roles**: Procurement Owner, Supplier Manager.
- **Status**: DRAFT → KYC_PENDING → ACTIVE → SUSPENDED → CLOSED.
- **Registers**: `scm.vendors`.
- **Signature**: not required.

Supplier Criticality Assessment

- **AR**: ■■■■■■ ■■■■■■■ ■■■■■■■
- Score vendor criticality (LOW/MEDIUM/HIGH/CRITICAL) based on services + spend.
- **Roles**: Supplier Manager.
- **Status**: DRAFT → SCORED → APPROVED.

Supplier Risk Assessment

- **AR**: ■■■■■■ ■■■■■■ ■■■■■■■
- Periodic risk assessment per vendor.
- **Roles**: Vendor Risk Manager.
- **Registers**: `scm.vendor_assessments`.
- **Status**: DRAFT → IN_PROGRESS → COMPLETED → APPROVED.

End-to-End Supply Chain Mapping

- **AR**: ■■■■ ■■■■■■ ■■■■■■ ■■■■■■■■ ■■■■■■■■
- Visual map: services → systems → primary → fourth-party vendors.
- **Module**: SCM (`Dependency.java`) + new Fourth-party module.
- **Status**: DRAFT → PUBLISHED.

Dependency Mapping

- **AR**: ■■■■ ■■■■■■ ■■■■■■■■■
- Per-system and per-process dependencies.
- **Registers**: `scm.dependencies`, `bcm.process_dependencies`.

Supplier BCM Evidence Review

- **AR**: ■■■■■■■ ■■■■■ ■■■■■■■■■■ ■■■■■■ ■■■■■■■
- Annual BCP + DR evidence review per critical vendor.
- **Roles**: BCM Officer + Vendor Risk Manager.
- **Signature**: optional.

Fourth-Party Risk Assessment

- **AR**: ■■■■■■ ■■■■■■■ ■■■■■■ ■■■■■■■
- Map vendors-of-vendors; detect concentration risk; validate; mitigate.

- **Module**: `scm/fourthparty/`. **State machine**: DISCOVERED → VALIDATED → MITIGATED → RETIRED.
- **Service**: `FourthPartyExposureService` with auto-CAPA on HIGH concentration.
- **Roles**: Vendor Risk Manager.
- **Registers**: `scm.fourth_party_exposures`.

Supplier SLA Monitoring

- **AR**: ■■■ ■■■■■■■■ ■■■■■■ ■■■■■■■
- Track SLA targets vs actuals per vendor.
- **Registers**: `scm.slas`.

Supplier Incident Escalation

- **AR**: ■■■■■■ ■■■■■■ ■■■■■■■
- Vendor-reported incidents → escalation per criticality.
- **Registers**: `scm.supplier_incidents`.

Alternate Supplier Planning

- **AR**: ■■■■■■ ■■■■■■■ ■■■■■■■
- Maintain 1-3 ranked alternates per critical vendor.
- **Module**: `scm/resilience/`. **State machine**: DRAFT → APPROVED → ARCHIVED.
- **Registers**: `scm.alternate_suppliers`.

Supplier Exit Planning

- **AR**: ■■■■■■ ■■■■■■■ ■■ ■■■■■■■
- 90-day exit plan: data, contracts, parallel-run.
- **State**: DRAFT → APPROVED → ACTIVATED → ARCHIVED (with REJECTED).
- **Action**: `recordTest(outcome, nextTestDue)`.

Supplier Resilience Testing

- **AR**: ■■■■■■■ ■■■■■ ■■■■■■■■■
- Tabletop / failover / exit-rehearsal / SLA / joint-crisis tests per vendor.
- **Module**: `scm/resilience/` (`SupplierResilienceTest`).
- **State**: SCHEDULED → IN_PROGRESS → COMPLETED → APPROVED / CANCELLED.
- **Service**: auto-CAPA on FAIL outcome.

Contractual Resilience Clause Review

- **AR**: ■■■■■■■ ■■■■■ ■■■■■■■ ■■■■■■■■■■
- Clause library + approval + deprecation.
- **Module**: `scm/clauses/`. **State**: DRAFT → APPROVED → DEPRECATED.

Supplier Corrective Action Tracking

- **AR**: ■■■■■■■ ■■■■■■■■■■ ■■■■■■■■■■ ■■■■■■■■■

- CAPAs originated from supplier workflows.
- **Module**: CAPA.

ERM Workflows

Risk Governance

- **AR**: ■■■■■■ ■■■■■■■■
- Charter + committee + appetite cadence.

Risk Appetite

- **AR**: ■■■■■ ■■■■■■■■ (■■■■■■■)
- Set per category + level; review annually.
- **Registers**: `risk.risk_appetite_statements`.

Risk Identification

- **AR**: ■■■■■■ ■■■■■■■■
- Bottom-up + top-down identification.
- **Status**: NEW → DRAFT.

Risk Assessment

- **AR**: ■■■■■■ ■■■■■■■■
- Likelihood × impact, inherent + residual.
- **Registers**: `risk.risk_assessments`.
- **Status**: DRAFT → ASSESSED → APPROVED.

Risk Treatment

- **AR**: ■■■■■■■ ■■■■■■■■
- Avoid / mitigate / transfer / accept.
- **Status**: DRAFT → IN_PROGRESS → IMPLEMENTED → VERIFIED.

Risk Acceptance

- **AR**: ■■■■■ ■■■■■■■■ ■■■■ ■■■■■
- Formal acceptance for above-appetite risks.
- **Signature**: required (CRO).
- **Status**: REQUESTED → APPROVED → ACTIVE → EXPIRED.

KRI Monitoring

- **AR**: ■■■■■■■ ■■■■■■■ ■■■■■■ ■■■■■■■■■
- Continuous monitoring with breach events.
- **Registers**: `risk.kri_definitions`, `risk.kri_breach_events`.

Control Management

- **AR**: ■■■■■■ ■■■■■■■■
- Control library + assessment + test.
- **Module**: Compliance + Cyber.

Issue Management

- **AR**: ■■■■■■ ■■■■■■■■■
- Issues raised from incidents, audits, KRI breaches.

Emerging Risk Management

- **AR**: ■■■■■■ ■■■■■■■■ ■■■■■■■■
- Horizon-scanning signals.
- **Module**: `risk/emerging/`. **State**: HORIZON → MONITORING → ESCALATED / MATURED / DISMISSED.

Scenario Analysis

- **AR**: ■■■■■■ ■■■■■■■■■■■■■
- Monte Carlo / stress / what-if.
- **Module**: `risk/scenario/`. **State**: DRAFT → APPROVED → ARCHIVED.

Risk Reporting

- **AR**: ■■■■■■■ ■■■■■■■■
- Board, executive, operational tiers.

Risk Committee Workflow

- **AR**: ■■■■ ■■■■■■■■
- Quarterly meetings, decisions, action items.
- **Module**: `admin/committee/`. **State**: SCHEDULED → IN_PROGRESS → COMPLETED → MINUTES_APPROVED → CANCELLED.

Lessons Learned Integration

- **AR**: ■■■ ■■■■■■■ ■■■■■■■■■■
- Cross-feeds from incidents + exercises into ERM.

PDPL / Privacy Workflows

Personal Data Processing Register (ROPA)

- **AR**: ■■■ ■■■■■■ ■■■■■■■ ■■■■■■■■■ ■■■■■■■■
- PDPL Art. 31.
- **Registers**: `privacy.processing_activities`.
- **Status**: DRAFT → ACTIVE → ARCHIVED.

Privacy Notice Management

- **AR**: ■■■■■■ ■■■■■■■■ ■■■■■■■■■

- PDPL Art. 12 templating + versioning.
- **Module**: `privacy/extensions/`. **State**: DRAFT → PUBLISHED → ARCHIVED → SUPERSEDED.

Consent Management

- **AR**: [redacted]
- Consent capture, withdrawal, audit.

Data Subject Rights Request

- **AR**: [redacted]
- 30-day SLA (PDPL Art. 22-26).
- **State**: NEW → IN_REVIEW → FULFILLED → REJECTED / EXPIRED.
- **Escalation**: at day 23 notify DPO; at day 28 escalate to Privacy Manager.
- **Signature**: required on response.

Privacy Impact Assessment (PIA)

- **AR**: [redacted]
- **State**: DRAFT → IN_REVIEW → APPROVED.
- **Signature**: required at APPROVED.

Data Sharing and Disclosure

- **AR**: [redacted]
- Formal disclosure agreements (regulator, credit bureau, group, JV).
- **Module**: `privacy/dsa/`. **State**: DRAFT → IN_REVIEW → ACTIVE → EXPIRED / TERMINATED.
- **Signature**: required at ACTIVE.

Cross-Border Data Transfer

- **AR**: [redacted]
- PDPL Art. 29; mechanism + assessment + approval + expiry.
- **Module**: `privacy/extensions/`. **State**: REQUESTED → ASSESSED → APPROVED / REJECTED → EXPIRED.

Personal Data Breach Management

- **AR**: [redacted]
- 72-hour SDAIA notification timer.
- **State**: DETECTED → CONTAINED → ASSESSED → NOTIFIED → CLOSED.
- **Auto-trigger** from cyber-bridge service.
- **Signature**: required at NOTIFIED.

Data Retention and Disposal

- **AR**: [redacted]
- PDPL Art. 18.

- **Module**: `privacy/extensions/`. **State**: SCHEDULED → IN_PROGRESS → COMPLETED → VERIFIED → CANCELLED.
- **Signature**: required at VERIFIED.

Processor and Third-Party Privacy Assessment

- **AR**: ■■■ ■■■■■■■ ■■■■■■■ ■■■■■■■■■
- PDPL Art. 28 eight-control assessment.
- **Module**: `privacy/processor/`. **State**: IN_PROGRESS → COMPLETED → APPROVED / REJECTED.
- **Auto-CAPA** on FAIL outcome.

NCA Workflows

NCA Framework Applicability

- **AR**: ■■■■ ■■■■■ ■■■■ NCA
- Decide which frameworks (ECC / CSCC / CCC / OTCC) apply.

NCA Control Library

- **AR**: ■■■■■ ■■■■■ NCA
- Maintain control catalogue.
- **Module**: `cyber/`. **Registers**: `cyber.cyber_controls` (145 controls seeded).

NCA Self-Assessment

- **AR**: ■■■■■■■ ■■■■■■ ■■ NCA
- Annual self-assessment + filing.
- **State**: DRAFT → IN_REVIEW → APPROVED → FILED.
- **Signature**: required at FILED (CISO).

Cybersecurity Risk Assessment

- **AR**: ■■■■■ ■■■■■■■ ■■■■■■■■■■
- Per-asset + per-control risk.

Asset and Critical System Classification

- **AR**: ■■■■■ ■■■■■■ ■■■■■■■■ ■■■■■■
- Classify assets (cyber + business).

Identity and Access Management Compliance

- **AR**: ■■■■■■■■ ■■■■■■ ■■■■■■ ■■■■■■■
- IAM control assessment.

Privileged Access Review

- **AR**: ■■■■■■ ■■■■■■ ■■■■■■■
- Quarterly review.

Vulnerability and Patch Compliance

- **AR**: ■■■■■■ ■■■■■■■■ ■■■■■■■■■
- Vuln pipeline.
- **Registers**: `cyber.vulnerabilities`.

Cyber Incident Management

- **AR**: ■■■■■■ ■■■■■■■■ ■■■■■■■■■■■
- NIST 800-61 lifecycle.
- **State**: DETECTION → ANALYSIS → CONTAINMENT → ERADICATION → RECOVERY → POST_INCIDENT → LESSONS_LEARNED.
- **Signature**: required at NOTIFIED (NCA).

Cloud Cybersecurity Compliance

- **AR**: ■■■■■■■■■ ■■■■■ ■■■■■■■■
- CCC framework — 30 controls.

OT / ICS Cybersecurity Compliance

- **AR**: ■■■■■■■■■ ■■■■■ ■■■■■■■■ ■■■■■■■■■■
- OTCC framework — 27 controls.

Cybersecurity Awareness and Training

- **AR**: ■■■■■■■■ ■■■■■■■■■ ■■■■■■■■■■
- Annual campaign + attestation.

NCA Corrective Action and Remediation

- **AR**: ■■■■■■■■■ ■■■■■■■■■■ ■■ NCA
- CAPAs from NCA self-assessment gaps.

Cross-Module Workflows

Regulatory Obligation Mapping

- **AR**: ■■■■ ■■■■■■■■■■■ ■■■■■■■■■■
- Map requirements across frameworks to controls.

Evidence Management

- **AR**: ■■■■■■ ■■■■■■■
- See Module 7.

Control Testing

- **AR**: ■■■■■■■ ■■■■■■■■
- Periodic operational testing.

Exception Management

- **AR**: ■■■■■■ ■■■■■■■■■■■■
- Risk-accepted control exceptions.
- **Registers**: `cyber.exceptions`.

Corrective Action Management

- **AR**: ■■■■■■ ■■■■■■■■■■ ■■■■■■■■■■
- See `capa/`.

Executive Reporting

- **AR**: ■■■■■■■■■ ■■■■■■■■■■
- See Output 11.

Board Reporting

- **AR**: ■■■■■■■ ■■■■■ ■■■■■■■■
- Board Pack PDF/PPTX.
- **Signature**: required (Chairman).

Regulatory Evidence Package Generation

- **AR**: ■■■■■ ■■■■■■■ ■■■■■■■■■■
- On-demand zip per regulator.

Digital Signature Approval

- **AR**: ■■■■■■■ ■■■■■■■■ ■■■■■■■
- Provider-pluggable (internal, DocuSign, Absher, Nafath).
- **Module**: `signature/`. **State**: REQUESTED → SIGNED / REJECTED / EXPIRED.

Audit Trail Review

- **AR**: ■■■■■■■ ■■■■ ■■■■■■■■
- Auditor-only read of `audit.events`.